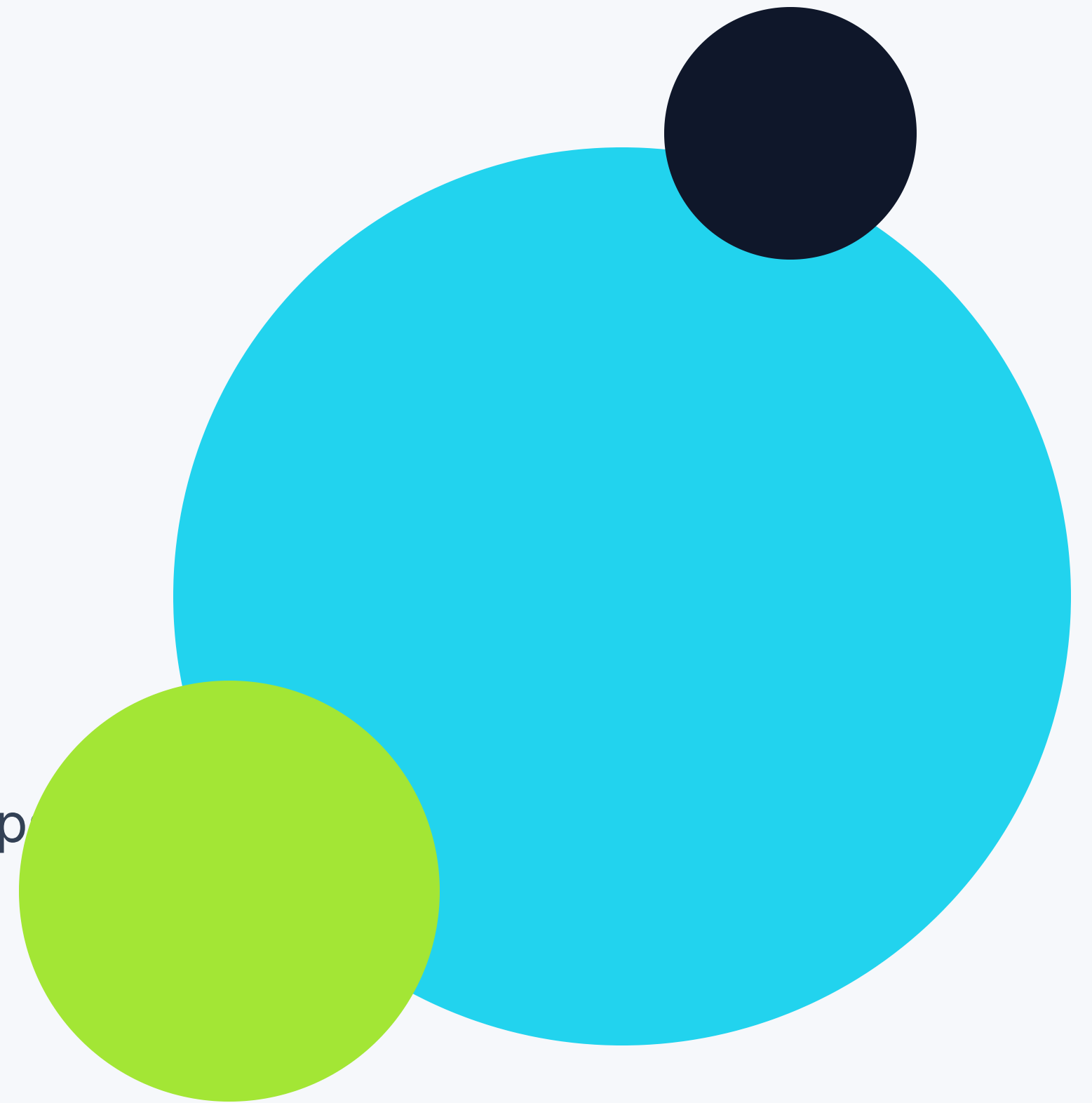


Workload identities

Apps, managed identities y Defender for Cloud App
20 a 25% del examen.



HOY, EN 45 MINUTOS

Tú ya estudiaste. Aquí cazamos trampas

5'

Mapa

Cuatro subdominios y cuatro preguntas: identidad, consent, entrada y Defender.

18'

Trampas

Doce trampas en diez slides, del molde y la galleta al session control.

18'

Kahoot

Diez preguntas del banco M3. Después de cada una, el porqué de cada distractor.

4'

Cierre

Qué estudiar antes de Governance y dónde están los links.

Cuatro subdominios, cuatro preguntas

**20 a
25%**

del examen. Las
identidades que no son
personas.

1 · Identities for apps and Azure workloads

Managed identities, service principals y cuentas de servicio. Trampas 2 y 3.

2 · Enterprise applications

App Proxy, SaaS SSO, consent, app roles y collections. Trampas 5 a 9.

3 · App registrations

Application object, authentication, API permissions y app roles. Trampas 1, 4 y 10.

4 · Defender for Cloud Apps

Cloud Discovery, CA app control, session policies y OAuth apps. Trampas 11 y 12.

LAS CUATRO PREGUNTAS QUE RESUELVEN CASI TODO M3

1 ¿Quién es la identidad?

Application object o service principal, system o user-assigned, y si vive dentro o fuera de Azure.

2 ¿Quién actúa y quién aprueba?

Delegated o application, qué rol puede consentir y qué hace el workflow cuando el usuario no puede.

3 ¿Por dónde entra el usuario?

SAML directo o App Proxy con pre-auth y KCD. Y qué settings de la app filtran, esconden o apagan.

4 ¿Qué ve y qué controla Defender?

Discovery por tráfico, connectors por API y proxy por Conditional Access.

El molde y la galleta

"App registration es el molde, enterprise app es la galleta: un molde en casa, una galleta por tenant."

HOME TENANT

App registration

Application object: uno solo. Sus cambios se reflejan en el SP del home tenant.



CADA TENANT

Enterprise app

Service principal: uno por tenant.
Multitenant crea uno en cada tenant que consiente.

SIN MOLDE

Managed identity

Solo service principal, sin application object. Sus permisos de Graph van directo al SP.

Delata:

home tenant

partner tenant grants consent

which object is created

¿Qué identidad le doy al workload?

"System-assigned vive y muere con su recurso; user-assigned es roomie. Y la managed identity no sale de Azure, salvo con Arc."

Azure, un recurso	System-assigned: una identidad, un recurso, se borra con él.
Azure, compartida	User-assigned: se asigna a muchos, se pre-autoriza y la borras tú.
Fuera de Azure	Con Arc, system-assigned. Sin Arc, service principal con cert o federated.
Windows on-prem	gMSA para varios servers o load balancer; sMSA para uno solo.

Roles de Azure RBAC, no de Entra: crear una user-assigned pide Managed Identity Contributor; asignarla a una VM, Virtual Machine Contributor + Managed Identity Operator.

Como tú, como yo y quién aprueba

"Delegated = actúo como tú; application = actúo como yo. Y 'como yo' siempre lo aprueba un admin."

	Delegated	Application
Usuario	Sí. La app no ve más que él	No. Ve todo lo del permiso
Se declara	Scope	App role
Consienten	Usuarios o admin	Solo admin
En Graph	App Admin o Cloud App Admin	Privileged Role Admin

Admin consent workflow

- Si el usuario no puede consentir, le da un botón para pedir.
- Ser reviewer no da superpoderes: para aprobar hace falta el rol.
- Los reviewers nuevos no ven solicitudes viejas, y estas expiran.
- Assignment required o scope Admins only: siempre admin.

La línea roja del App Proxy

"Cloud App Admin es App Admin sin el Proxy. Y ninguno de los dos toca CA ni Graph application permissions."



Application Administrator

Todo en enterprise apps y app registrations, más Application Proxy y connector groups.



Cloud Application Administrator

Lo mismo sin Application Proxy. Sí configura SAML SSO y consiente delegated de Graph.



Application Developer

Rol mínimo para registrar apps si Users can register applications está en No.

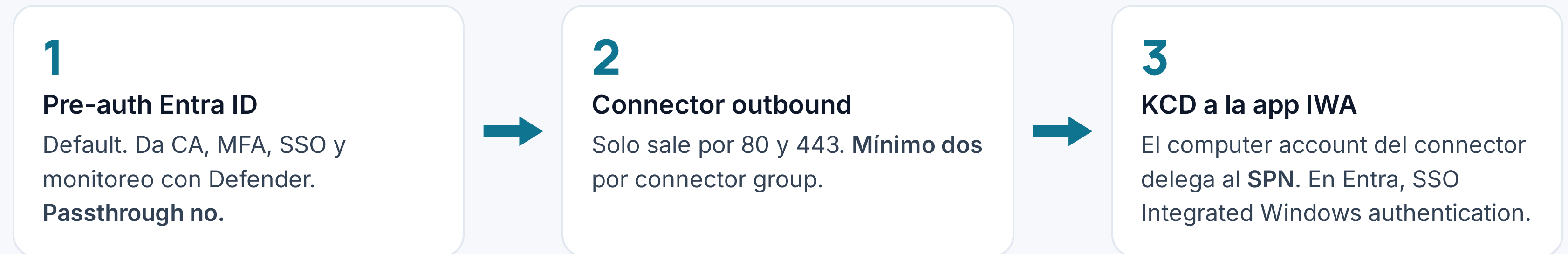


Privileged Role Administrator

Consiente application permissions de Microsoft Graph (o Global Admin).

App Proxy de punta a punta

"Sin pre-auth de Entra no hay CA, ni MFA, ni SSO. El connector solo sale, nunca entra."



Custom domain: PFX con private key + CNAME a msappproxy.net. **Dominios distintos:** resource-based KCD. Licencia P1 o P2.

SAML sin sustos

"Entity ID dice quién eres, Reply URL dice a dónde mando el token. El cert no se edita: se crea otro."

Basic SAML Configuration

- **Identifier (Entity ID):** obligatorio.
- **Reply URL (ACS):** obligatorio, ahí llega el token.
- **Sign on URL:** solo para SP-initiated.
- Login URL y Microsoft Entra Identifier de "Set up" van al vendor.

Rollover sin downtime

1. Nuevo cert con fecha traslapada.
 2. Descargarlo y subirlo a la app.
 3. **Make certificate active.**
 4. Probar el sign-in.
- Autogenerado: 3 años. Avisos a 60, 30 y 7 días.

Delata:

Assertion Consumer Service

SP-initiated

no downtime

change the expiration date

Esconder, filtrar o apagar

"Visible esconde, Assignment required filtra, Enabled apaga. Y los grupos anidados no cuentan."



Visible to users: No

Esconde la app en My Apps. El acceso sigue igual.



Assignment required: Yes

Filtra: solo los asignados obtienen token.



Enabled for users to sign in: No

Apaga: no hay tokens para nadie, sin perder la configuración.

Grupos: asignar pide P1 o P2 y no cascada a grupos anidados. **Collections** (App launchers, P1 o P2): una pestaña en My Apps, solo con apps ya asignadas.

Scope, app role o groups claim

"Scope para 'on behalf of', app role para 'sin usuario' o para roles de usuario; el groups claim topa en 200."

Si la pregunta dice	Configura
"React", "MSAL.js", "PKCE"	Redirect URI en la plataforma Single-page application
"daemon", sin usuario	Sin redirect URI; app role con Allowed member types Applications
"on behalf of the signed-in user"	Scope en Expose an API, con el App ID URI primero
"roles claim"	App role Users/Groups , asignado en Enterprise apps
"more than 200 groups"	Groups assigned to the application (límite 200 JWT, 150 SAML)

Ojo: un app role dado a un grupo que contiene un service principal **no emite** el claim roles.

Unsanctioned no es un firewall

"Unsanctioned es una etiqueta, no un firewall: el bloqueo lo hace MDE o tu appliance."

SNAPSHOT

Subes logs a mano, **una vez**. Es el one-time assessment de logs exportados.

CONTINUOUS

Defender for Endpoint (también fuera de la oficina), log collector (Syslog o FTP), SWG o API.

BLOQUEAR CON MDE

1. Cloud y Network Protection.
 2. Enforce app access.
 3. Custom network indicators.
 4. Unsanctioned: hasta 3 horas.
- Scoped profiles: por device group.

Catalog: más de 31,000 apps en 4 categorías. **Score metrics** cambia pesos para todas las apps; **Override**, para una; **Request score update** le pide a Microsoft.

Session control: quién hace qué

"Session policy sin el CA 'Use Conditional Access App Control' es perro sin dientes. Y app enforced solo muerde en Exchange y SharePoint."



Access policy

Entrar o no. Con Client app = **Mobile and desktop** bloquea clientes nativos.



Session policy

Qué haces dentro, **solo en browser**. Access y session piden el CA con App Control.



App enforced restrictions

Solo **Exchange Online y SharePoint Online**, sin licencia de Defender for Cloud Apps.



App connector y OAuth apps

Connector = API, sin proxy. OAuth app policy: permission level, community use, **Revoke app**.

BLOQUE 3 · 18 MINUTOS

Kahoot

Diez preguntas del banco M3, 60 segundos cada una. Ganar no es el punto: **el porqué de cada distractor** sí.

kahoot.it

PIN: en vivo

Graph para una managed identity

FuncHR's system-assigned managed identity needs the Graph application permission User.Read.All. How do you grant it?

A App registrations: add it and select Grant admin consent

✓ App role assignment from the Graph SP to the identity's SP

C Reader Azure role on the subscription

D Enterprise applications: add it on the Permissions page

Por qué

Una managed identity **solo tiene service principal**, sin application object. Los permisos de Graph se dan **directo a su SP** con una app role assignment.

A. La managed identity no aparece en App registrations: no hay API permissions.

C. Azure RBAC da acceso a recursos de Azure, no a datos de Graph.

D. La página Permissions muestra y revisa permisos; no los agrega.

Una identidad para todo el scale set

Scale set instances are re-created daily. One shared identity, pre-authorized to Key Vault, no secrets. Which identity?

☒ **User-assigned managed identity assigned to the scale set**

☐ **B** System-assigned managed identity on each instance

☐ **C** App registration with a client secret in app settings

☐ **D** Synced AD user account used as a service account

Por qué

La **user-assigned** tiene ciclo de vida independiente y se asigna a muchos recursos. Learn la pone para **pre-autorizar** y para recursos que se reciclan seguido.

B. Nace y muere con cada instancia, y no existe antes del deploy.

C. Funciona, pero obliga a manejar y rotar un secreto.

D. User accounts como service accounts no se recomiendan.

GitHub sin secretos

GitHub Actions deploys to Azure via app registration Deployer. No secrets or certs stored in GitHub. Which credential?

- A A client secret with a 24-month expiration
- B A certificate, private key kept as a GitHub encrypted secret
- ☒ C A federated credential for GitHub Actions deploying Azure resources
- D A system-assigned managed identity on the GitHub-hosted runner

Por qué

La **federated credential** deja que GitHub Actions cambie su token por uno de Microsoft Entra **sin guardar secretos**.

A. Es un secreto, y 24 meses es el máximo permitido.

B. El cert es mejor, pero su private key en GitHub rompe la regla.

D. Un runner de GitHub no es recurso de Azure: no tiene managed identity.

Pedir aprobación desde el prompt

Users can't consent to an unverified app and have no way to ask for it. Enable requests without weakening security?

A Change user consent to Allow user consent for apps

B Classify the requested permission as low impact

C Disable risk-based step-up consent

✓ Turn on the admin consent workflow and select reviewers

Por qué

El **admin consent workflow** deja que el usuario pida aprobación desde el prompt. La solicitud llega a los reviewers y **no cambia** lo que el usuario puede consentir.

A. Quita la protección de verified publishers: baja la seguridad.

B. Aunque fuera low impact, el publisher sigue sin estar verificado.

C. No es la causa del bloqueo, y apagarlo reduce la seguridad.

App Proxy con least privilege

Marta must publish apps with Application Proxy, create connector groups and set up SAML SSO. Least privilege role?

A Cloud Application Administrator

☒ Application Administrator

C Application Developer

D Global Administrator

Por qué

Application Administrator administra enterprise apps y app registrations **más Application Proxy**. Es el least privileged para App Proxy y connector groups.

A. Tiene lo mismo excepto Application Proxy. Esa es toda la diferencia.

C. Solo registra apps. No toca App Proxy ni SSO de apps ajenas.

D. Puede todo, pero rompe least privilege.

expenses.contoso.com con App Proxy

An App Proxy app must use https://expenses.contoso.com. The domain is already verified. What else do you need?

- A .cer certificate and an A record to the connector's public IP
- B Only a TXT record; Microsoft provides the certificate
- ☒ C PFX with the private key and a CNAME to the msappproxy.net address
- D Certificate on the connector server and inbound TCP 443 open

Por qué

Custom domain = certificado **PFX con private key**, subido en la página Application proxy de la app, más un **CNAME** al dominio msappproxy.net.

A. Un .cer no trae private key, y no se apunta a IPs de servers.

B. El TXT es para verificar el dominio, paso que ya está hecho.

D. El connector no recibe tráfico de internet: todo es outbound.

Finance-Contractors no entra

Expensely: Assignment required, group Finance assigned, finance-only. Nested Finance-Contractors can't sign in. Fix?

- A Set Assignment required to No on Expensely
- B Set Visible to users to Yes on Expensely
- C Add Finance-Contractors as an owner of Expensely
- ☒ **Assign Finance-Contractors directly to Expensely**

Por qué

En la asignación a apps **los grupos anidados no cuentan**: la asignación no cascada. Asigna Finance-Contractors directo (pide P1 o P2).

A. Entraría todo el tenant: ya no es solo finanzas.

B. Visible solo decide si se ve en My Apps. No da acceso.

C. Los owners administran la app; no reciben acceso por eso.

Un claim con Survey.Create

Tokens must carry a claim with value Survey.Create. Admins will grant it to users and groups. What do you configure?

- A A scope named Survey.Create in Expose an API
- B A groups claim in Token configuration
- ☒ **App role (Users/Groups, value Survey.Create), assigned in Enterprise apps**
- D A custom Microsoft Entra directory role named Survey.Create

Por qué

Un app role con Allowed member types **Users/Groups** sale en el claim **roles** con el Value que definiste. Luego lo asignas en Enterprise apps.

A. Un scope es un permiso delegated: sale en scp, no es el rol del usuario.

B. Manda object IDs de grupos; el código tendría que mapearlos.

D. Los roles de directorio administran Entra, no la lógica de tu app.

Logs exportados, una sola vez

30 days of Palo Alto logs were exported. You need a one-time cloud app assessment, deploying nothing. What do you do?

- ☒ **Create a snapshot report and upload the log files**
- ☐ B Deploy a log collector and forward the logs over Syslog
- ☐ C Turn on the Defender for Endpoint integration
- ☐ D Connect the firewall with an app connector

Por qué

El **snapshot report** da visibilidad ad hoc sobre logs que **subes a mano**. Palo Alto está en la lista de fuentes soportadas.

B. El log collector es para reportes continuos y se despliega en la red.

C. También es continuo y mira endpoints, no los logs exportados.

D. Los app connectors van por API a apps SaaS, no a firewalls.

La session policy no hace nada

A Salesforce session policy blocks downloads on unmanaged devices. Users still download. No CA policy targets it. Fix?

A Connect Salesforce with an app connector

☒ CA policy for Salesforce with Use Conditional Access App Control

C CA policy for Salesforce with Use app enforced restrictions

D Tag Salesforce as Sanctioned in the catalog

Por qué

Access y session policies necesitan que una **política de CA mande la sesión** a Defender for Cloud Apps: Use Conditional Access App Control, con Use custom policy.

A. El connector trabaja por API. No controla la sesión del browser.

C. Solo funciona con Exchange Online y SharePoint Online.

D. Sanctioned es una etiqueta de discovery. No enruta sesiones.

Antes de la sesión 4: Governance



Estudia M4

Guía del estudiante M4 y su banco de 40 preguntas: entitlement management, access reviews, PIM y logs. Pesa 20 a 25%.



Repasa M3

Vuelve a lo que fallaste hoy. En cada pregunta del banco, señala las dos o tres palabras que delatan la respuesta.



Ojo con los nombres

En el banco y en Learn, el connector de App Proxy aparece como **private network connector**. Es el mismo.

Si presentas el examen esta semana: llena el debrief el mismo día. Temas sí, preguntas no.

RECURSOS, TODOS CON LINK

Todo es público y de Microsoft Learn



Study guide y skills outline

Study guide for Exam SC-300



Practice assessment gratis

Practice Assessment SC-300



Learning path de M3

Implement access management for apps



Managed identities

Access management for Azure resources (módulo)



Defender for Cloud Apps

Cloud Discovery con Defender for Cloud Apps (módulo)



Labs oficiales del curso

SC-300 Labs index en GitHub